

## ACTIVIDAD 04

# UNA PÁGINA DEMASIADO CONVINCENTE

Simulación controlada de ingeniería social con Social-Engineer Toolkit (SET)

**BRYHAN EDUARDO GUZMAN MARTINEZ**

**178508**

**FUNDAMENTOS DE CIBERSEGURIDAD**

# ÍNDICE

|                                                                                   |                               |
|-----------------------------------------------------------------------------------|-------------------------------|
| ÍNDICE.....                                                                       | ¡Error! Marcador no definido. |
| 1. Objetivo de la actividad.....                                                  | 3                             |
| 1.1 Objetivo general.....                                                         | 3                             |
| 1.2 Objetivos específicos .....                                                   | 3                             |
| 2. Descripción del escenario.....                                                 | 3                             |
| 3. Configuración del laboratorio.....                                             | 4                             |
| 4. Credential Harvester: concepto y función.....                                  | 5                             |
| 5. Evidencias y descripción del funcionamiento .....                              | 6                             |
| 5.1 Inicio de SET y selección del vector web .....                                | 6                             |
| 5.2 Configuración del Credential Harvester .....                                  | 8                             |
| 5.3 Importación de la página y puesta en servicio.....                            | 9                             |
| 5.4 Servidor local y portal de prueba .....                                       | 10                            |
| 5.5 Registro de parámetros recibidos .....                                        | 11                            |
| 6. Explicación del flujo de captura de información .....                          | 12                            |
| 6.1 Interpretación de las peticiones HTTP .....                                   | 12                            |
| 6.2 Captura de credenciales vs. vulneración de una contraseña.....                | 12                            |
| 7. Indicadores de phishing y medidas de protección .....                          | 13                            |
| 7.1 Indicadores que permiten reconocer una página potencialmente fraudulenta..... | 13                            |
| 7.2 Controles de seguridad propuestos .....                                       | 13                            |
| 7.3 Relación entre indicadores y controles.....                                   | 14                            |
| 8. Conclusión.....                                                                | 15                            |
| 9. Referencias .....                                                              | 16                            |

# 1. Objetivo de la actividad

## 1.1 Objetivo general

Implementar y analizar, dentro de un entorno de laboratorio controlado, una simulación de ingeniería social utilizando Social-Engineer Toolkit (SET) y una página web ficticia, con el propósito de comprender cómo puede capturarse la información introducida en un formulario y reconocer los elementos que permiten identificar un intento de phishing.

## 1.2 Objetivos específicos

- Configurar un escenario básico de ingeniería social mediante Social-Engineer Toolkit (SET).
- Implementar una página web ficticia con campos de usuario y contraseña mediante el módulo Credential Harvester.
- Analizar el recorrido de la información desde el navegador hasta el servidor local de SET.
- Identificar evidencias técnicas de la comunicación HTTP y del registro de parámetros enviados por el formulario.
- Reconocer indicadores visuales y técnicos de phishing.
- Proponer controles de seguridad que ayuden a prevenir o reducir el impacto de ataques de ingeniería social.

# 2. Descripción del escenario

El escenario simula la situación de una organización cuyos empleados reciben un mensaje relacionado con una supuesta actualización de credenciales. El enlace conduce a un portal aparentemente institucional que muestra un aviso de sesión expirada e invita a volver a iniciar sesión. Aunque la interfaz parece legítima a primera vista, el portal no pertenece a una organización real y se ejecuta únicamente dentro del laboratorio.

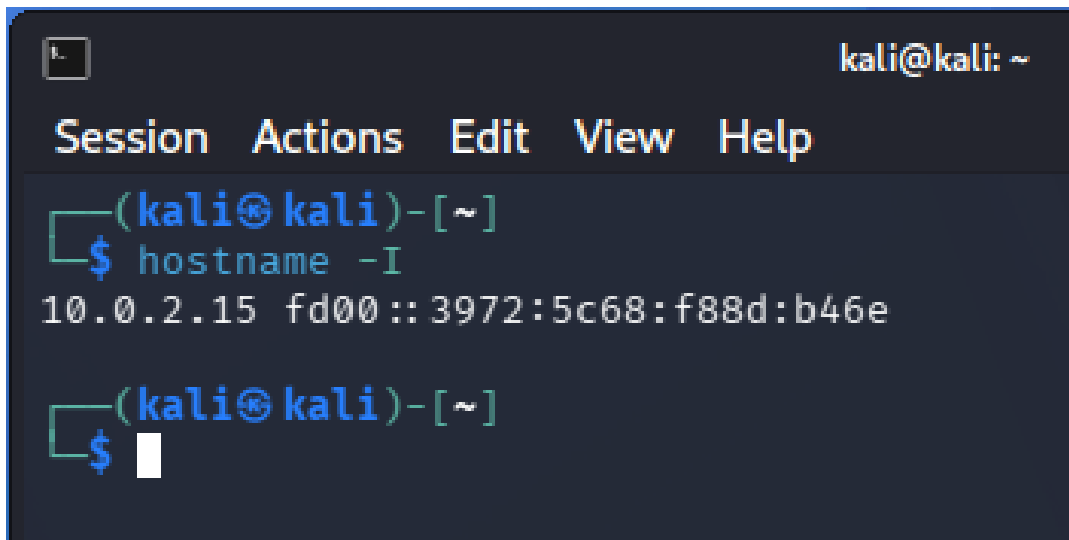
Para representar este escenario se creó una página web local denominada “Portal Académico”, con un campo de usuario, un campo de contraseña, un botón de ingreso y el mensaje “Su sesión ha expirado. Inicie sesión nuevamente para continuar”. La página fue cargada en el módulo Credential Harvester de SET y servida mediante HTTP desde la dirección local 10.0.2.15.

La simulación se mantuvo dentro de Kali Linux y VirtualBox. No se utilizaron páginas pertenecientes a servicios reales, no se clonaron portales externos, no se enviaron mensajes a personas ajenas al laboratorio y no se utilizaron dominios externos. Tampoco se ejecutaron payloads, malware ni técnicas de suplantación DNS.

### 3. Configuración del laboratorio

La práctica se ejecutó en una máquina virtual Kali Linux hospedada en Oracle VirtualBox. La interfaz de red de la máquina virtual utilizó una dirección IPv4 privada y el servidor del **Credential Harvester** quedó limitado al entorno local de la práctica.

| Elemento          | Configuración utilizada                                                       |
|-------------------|-------------------------------------------------------------------------------|
| Hipervisor        | Oracle VirtualBox                                                             |
| Sistema operativo | Kali Linux 2026.2                                                             |
| Herramienta       | Social-Engineer Toolkit (SET)                                                 |
| Vector            | Website Attack Vectors                                                        |
| Método            | Credential Harvester Attack Method                                            |
| Tipo de sitio     | Custom Import de una página HTML creada específicamente para el laboratorio   |
| Ruta local        | /home/kali/act04/                                                             |
| Dirección IPv4    | 10.0.2.15                                                                     |
| Servidor          | HTTP local                                                                    |
| Navegador         | Firefox dentro de Kali Linux                                                  |
| Datos de prueba   | Usuario y contraseña ficticios; sin información personal o institucional real |



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ hostname -I  
10.0.2.15 fd00::3972:5c68:f88d:b46e  
(kali@kali)-[~]  
$
```

Ilustración 1. Identificación de la dirección IPv4 privada de Kali Linux mediante `hostname -I`.

La dirección 10.0.2.15 fue utilizada como punto de retorno (POST back) y como dirección del servidor web local. Al ser una dirección privada de la máquina virtual, la práctica se mantuvo dentro del laboratorio.

## 4. Credential Harvester: concepto y función

Credential Harvester es un método de SET diseñado para recibir y registrar los parámetros enviados por formularios web. Dentro de una simulación de phishing, su función consiste en alojar o importar una página web y observar los datos que el navegador envía cuando un usuario completa y envía un formulario.

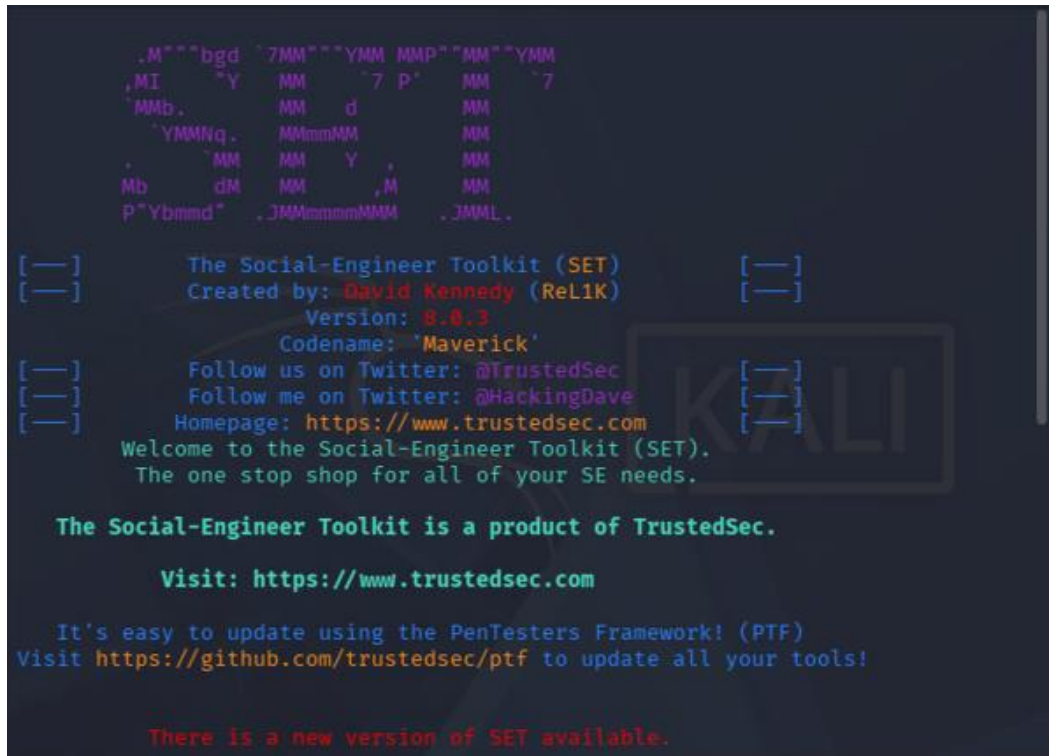
En esta actividad se empleó únicamente con una página de prueba y credenciales ficticias. Cuando el formulario se envía, el navegador genera una solicitud HTTP hacia el servidor local. SET analiza los parámetros recibidos e identifica campos que podrían corresponder a un usuario y a una contraseña.

Este comportamiento permite comprender por qué una página de phishing puede ser peligrosa incluso sin contener código malicioso: si el usuario confía en una interfaz falsa y entrega voluntariamente sus credenciales, el atacante puede obtenerlas directamente mediante el formulario.

## 5. Evidencias y descripción del funcionamiento

Las siguientes evidencias muestran el proceso realizado de forma ordenada. Se incluyen únicamente los pasos relevantes para el escenario de Credential Harvester.

### 5.1 Inicio de SET y selección del vector web



```

.M***bgd 7MM***YMM MMP**MM**YMM
,MI      ^Y  MM      7 p^  MM      7
`MMb.      MM      d      MM
`YMMNq.    MMmmMM      MM
      MM      MM      Y      MM
Mb      dM      MM      ,M      MM
P**Ybmmd* .JMMmmmmMMM .JMML.

[—] The Social-Engineer Toolkit (SET) [—]
[—] Created by: David Kennedy (ReL1K) [—]
      Version: 8.0.3
      Codename: 'Maverick'
[—] Follow us on Twitter: @TrustedSec [—]
[—] Follow me on Twitter: @HackingDave [—]
[—] Homepage: https://www.trustedsec.com [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.

```

Ilustración 2. Inicio de Social-Engineer Toolkit en Kali Linux.

SET se inició desde Kali Linux. La herramienta mostró su menú principal y los módulos disponibles para prácticas de ingeniería social.

```
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 
```

Ilustración 3. Menú de Social-Engineering Attacks con la opción Website Attack Vectors.

Se seleccionó Website Attack Vectors, ya que la actividad requiere trabajar con una página web ficticia. El módulo Mass Mailer no fue utilizado para la ejecución final.

## 5.2 Configuración del Credential Harvester

```

set:webattack>3 ~
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

--
-- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * --
--

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 10.0.2.15

```

Ilustración 4. Configuración de la dirección 10.0.2.15 como IP de retorno del Credential Harvester.

SET solicitó la dirección IP para recibir el POST del formulario. Se indicó 10.0.2.15, correspondiente a la interfaz IPv4 de Kali Linux.

```

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 10.0.2.15
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned:

```

Ilustración 5. Importación de la carpeta local que contiene index.html.

La página se almacenó en /home/kali/act04/. SET verificó la existencia de index.html y solicitó definir si debía copiarse únicamente ese archivo o toda la carpeta.

### 5.3 Importación de la página y puesta en servicio

```
set:webattack> IP address for the POST back in Harvester/abnabbing [10.0.2.15]: 10.0.2.15
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/act04/
[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html
2. Copy the entire folder

Enter choice [1/2]: 2
```

Ilustración 6. Selección de la copia de la carpeta completa del sitio de prueba.

Se seleccionó la copia de la carpeta completa debido a que el sitio también incluía una hoja de estilos CSS.

```
Enter choice [1/2]: 2
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: 
```

Ilustración 7. Definición de la URL local del sitio importado.

Se indicó `http://10.0.2.15/` como URL local. No se utilizó ningún dominio externo ni una página perteneciente a una organización real.

## 5.4 Servidor local y portal de prueba

```
[*] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://10.0.2.15/

The best way to use this attack is if username and password form fields are a
vailable. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

Ilustración 8. Credential Harvester ejecutándose en el puerto 80.

La terminal confirmó que el Credential Harvester estaba en ejecución sobre el puerto 80 y que mostraría la información recibida conforme llegaran las solicitudes.

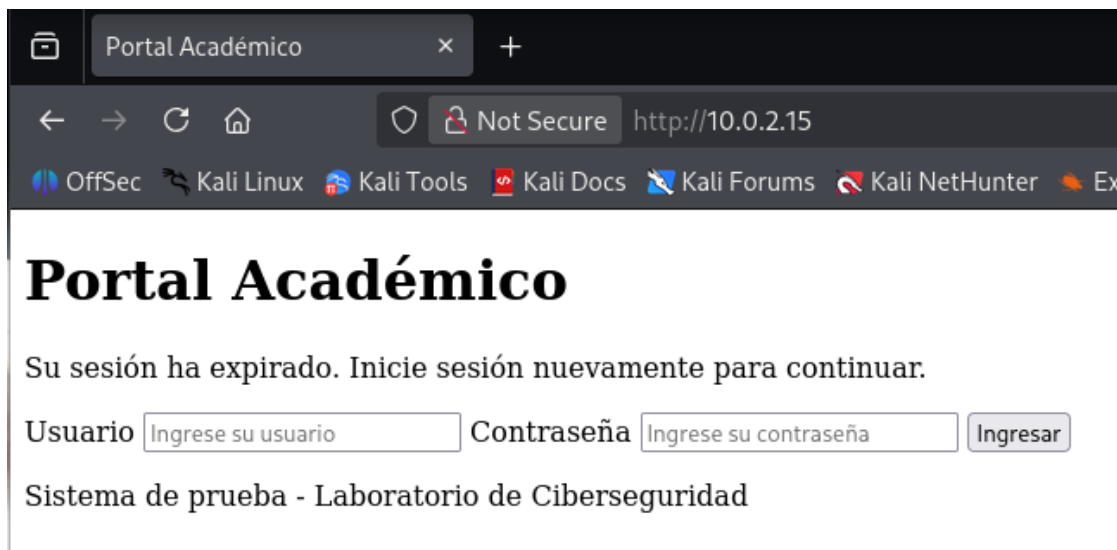
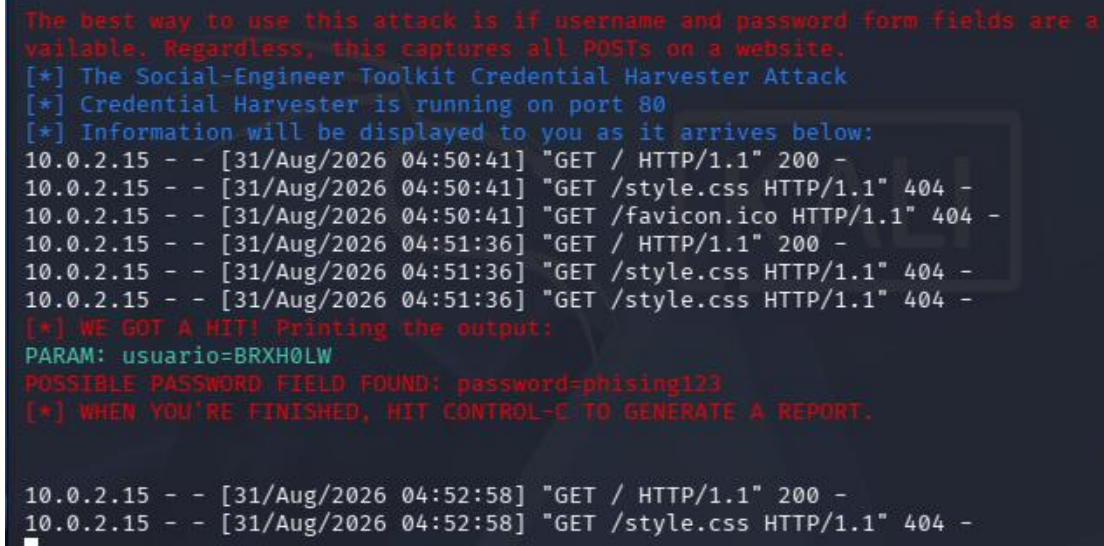


Ilustración 9. Portal Académico ficticio abierto desde Firefox en la dirección 10.0.2.15.

El navegador mostró el formulario diseñado para el laboratorio. El aviso “Not Secure” es consistente con el uso de HTTP sin TLS dentro del entorno local. Se ingresaron únicamente datos ficticios para comprobar el flujo de la solicitud.

## 5.5 Registro de parámetros recibidos



```
The best way to use this attack is if username and password form fields are a
vailable. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
10.0.2.15 - - [31/Aug/2026 04:50:41] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [31/Aug/2026 04:50:41] "GET /style.css HTTP/1.1" 404 -
10.0.2.15 - - [31/Aug/2026 04:50:41] "GET /favicon.ico HTTP/1.1" 404 -
10.0.2.15 - - [31/Aug/2026 04:51:36] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [31/Aug/2026 04:51:36] "GET /style.css HTTP/1.1" 404 -
10.0.2.15 - - [31/Aug/2026 04:51:36] "GET /style.css HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: usuario=BRXH0LW
POSSIBLE PASSWORD FIELD FOUND: password=phising123
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

10.0.2.15 - - [31/Aug/2026 04:52:58] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [31/Aug/2026 04:52:58] "GET /style.css HTTP/1.1" 404 -
```

Ilustración 10. SET registra los parámetros enviados por el formulario y detecta el campo de contraseña.

Después de enviar el formulario, SET mostró el mensaje “WE GOT A HIT!” y registró los parámetros correspondientes al usuario y al campo identificado como posible contraseña. La evidencia confirma que la información viajó desde el navegador hasta el servidor de SET.

También se observan solicitudes GET al recurso principal con código 200 y solicitudes a style.css con código 404. El código 200 indica que el documento principal se entregó correctamente. El 404 corresponde únicamente a un recurso de estilo que no fue localizado; por ello la página se mostró sin formato visual, pero el formulario siguió funcionando y el envío de parámetros se completó correctamente.

## 6. Explicación del flujo de captura de información

El flujo observado durante la simulación puede resumirse de la siguiente manera:

### 1. Usuario de prueba

Abre `http://10.0.2.15/` desde Firefox.



### 2. Página HTML ficticia

El navegador solicita el recurso principal mediante HTTP y recibe `index.html`.



### 3. Formulario HTTP POST

El usuario ficticio escribe valores de prueba y presiona “Ingresar”.



### 4. SET / Credential Harvester

El servidor local en el puerto 80 recibe la solicitud, analiza los parámetros y registra los campos usuario y password.

## 6.1 Interpretación de las peticiones HTTP

Las líneas “GET / HTTP/1.1 200” corresponden a la solicitud del documento principal. El navegador también intentó recuperar `style.css`; al no estar disponible en el servidor utilizado por SET, recibió un código 404. Estas peticiones GET corresponden a recursos de la página, mientras que el envío de los valores del formulario se realiza mediante POST.

Cuando SET recibe el POST, analiza los nombres de los campos y muestra los valores recibidos. En la evidencia aparece el parámetro de usuario y un “POSSIBLE PASSWORD FIELD FOUND”, lo cual confirma que identificó el campo password del formulario.

## 6.2 Captura de credenciales vs. vulneración de una contraseña

La captura de credenciales ocurre porque el usuario proporciona los datos a una página que considera legítima. No se necesita descifrar una contraseña: el dato es recibido como parte del formulario. En cambio, la vulneración de una contraseña mediante fuerza bruta, cracking de hashes o explotación de un mecanismo de autenticación implica técnicas distintas y no fueron realizadas en esta práctica.

## 7. Indicadores de phishing y medidas de protección

### 7.1 Indicadores que permiten reconocer una página potencialmente fraudulenta

**Urgencia o presión:** Mensajes como “su sesión ha expirado” buscan provocar una respuesta rápida y reducir la verificación por parte del usuario.

**URL o dominio inesperado:** El dominio debe coincidir exactamente con el servicio legítimo. Direcciones desconocidas, IP directas o variaciones ortográficas son señales de alerta.

**Uso de HTTP o advertencias del navegador:** La ausencia de HTTPS y mensajes como “Not Secure” indican que la conexión no está protegida mediante TLS. Aunque HTTPS por sí solo no garantiza legitimidad, su ausencia en un portal de autenticación es un indicador importante.

**Solicitud inesperada de credenciales:** Un enlace recibido por correo o mensajería que solicita volver a introducir usuario y contraseña debe verificarse directamente desde el portal oficial.

**Errores de diseño o recursos faltantes:** Diferencias en tipografía, imágenes, estilos, enlaces rotos o recursos 404 pueden revelar que la página no corresponde al sitio oficial.

**Mensajes o remitentes no habituales:** Correos con remitentes desconocidos, dominios parecidos al real o contenido fuera del contexto normal de la organización requieren revisión.

**Enlaces cuyo destino no coincide con el texto:** Antes de abrir un enlace, conviene revisar su destino. Un texto que aparenta pertenecer a una institución puede dirigir a otra ubicación.

### 7.2 Controles de seguridad propuestos

**Autenticación multifactor resistente al phishing:** Utilizar métodos como FIDO2, WebAuthn o passkeys reduce el impacto de una contraseña capturada porque la autenticación queda vinculada al dominio legítimo.

**Capacitación y simulaciones periódicas:** Formar a los usuarios para reconocer urgencia, dominios falsos, adjuntos sospechosos y solicitudes inusuales. Debe existir un canal sencillo para reportar mensajes.

**Filtrado de correo y autenticación del dominio:** Implementar controles antiphishing y políticas SPF, DKIM y DMARC para reducir la suplantación de remitentes y bloquear mensajes maliciosos.

**Filtrado DNS/URL y protección del navegador:** Bloquear dominios conocidos por phishing, categorías de riesgo y direcciones recién registradas ayuda a impedir el acceso a portales fraudulentos.

**HTTPS, HSTS y prácticas seguras de autenticación:** Los portales institucionales deben utilizar TLS correctamente configurado, HSTS y mecanismos de autenticación que reduzcan la exposición de credenciales.

**Gestores de contraseñas:** Los gestores suelen asociar cada credencial con el dominio legítimo. Si no autocompletan en una página extraña, pueden servir como señal de alerta para el usuario.

**Monitoreo y respuesta a incidentes:** Registrar intentos de autenticación anómalos, detectar accesos desde ubicaciones o dispositivos inusuales y restablecer credenciales comprometidas con rapidez.

### 7.3 Relación entre indicadores y controles

| Indicador observado              | Riesgo principal                                | Control recomendado                             |
|----------------------------------|-------------------------------------------------|-------------------------------------------------|
| Urgencia / sesión expirada       | Entrega impulsiva de credenciales               | Capacitación y acceso directo al portal oficial |
| IP directa o dominio inesperado  | Suplantación del servicio                       | Filtrado URL/DNS y verificación del dominio     |
| HTTP / “Not Secure”              | Intercepción o ausencia de protección del canal | HTTPS + HSTS                                    |
| Solicitud de contraseña          | Robo de credenciales                            | MFA resistente al phishing y passkeys           |
| Diseño incompleto o recursos 404 | Página no legítima o mal replicada              | Verificación visual y gestores de contraseñas   |

## 8. Conclusión

La actividad permitió observar de forma práctica cómo una página web aparentemente legítima puede utilizarse para obtener información mediante ingeniería social. Al configurar Credential Harvester dentro de SET, se comprobó que el navegador envía los valores escritos en un formulario al servidor que procesa la solicitud, y que esos parámetros pueden quedar registrados por la herramienta.

La evidencia mostró el funcionamiento del servidor HTTP local, la entrega correcta del documento principal mediante una respuesta 200, el intento de carga de un recurso CSS no disponible mediante una respuesta 404 y, principalmente, el registro de los campos enviados por el formulario. Esto permitió relacionar conceptos de HTTP, servidor web, parámetros de formularios y técnicas de phishing dentro de un entorno seguro y controlado.

El aprendizaje más importante es que la seguridad no depende únicamente de la complejidad técnica del ataque. En muchos casos, el factor decisivo es que el usuario confíe en un mensaje o una página falsa y proporcione voluntariamente información sensible. Por ello, la prevención debe combinar controles técnicos —como MFA resistente al phishing, filtrado de correo, HTTPS y monitoreo— con capacitación para reconocer dominios, mensajes y solicitudes sospechosas.

Finalmente, esta práctica también demuestra la importancia de delimitar el alcance de las pruebas de ciberseguridad. Todas las acciones se realizaron de forma local, con datos ficticios y sin afectar servicios, usuarios o infraestructura externa.

## 9. Referencias

Cybersecurity and Infrastructure Security Agency. (s. f.). Recognize and report phishing. CISA.  
<https://www.cisa.gov/secure-our-world/recognize-and-report-phishing>

MITRE. (s. f.). Phishing (T1566). MITRE ATT&CK. <https://attack.mitre.org/techniques/T1566/>

National Institute of Standards and Technology. (2020). Digital identity guidelines: Authentication and lifecycle management (NIST SP 800-63B). <https://doi.org/10.6028/NIST.SP.800-63b>

OWASP Foundation. (s. f.). Authentication cheat sheet. OWASP Cheat Sheet Series.  
[https://cheatsheetseries.owasp.org/cheatsheets/Authentication\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html)

TrustedSec. (s. f.). Social-Engineer Toolkit (SET) [Software]. GitHub.  
<https://github.com/trustedsec/social-engineer-toolkit>